

Rapport de Test d’Intrusion – Bug&Blog Ltd

Client : Client

Date du Rapport : 28/02/25

Type de Test : boîte grise

Durée du Test : 4h

CONFIDENTIEL

Rapport de Test d’Intrusion – Bug&Blog Ltd.....	1
1. Préambule et Contexte	2
2. Exécutif – Résumé pour la Direction.....	2
3. Analyse Technique – Détail des Vulnérabilités	3
3.1 Vulnérabilité FTP – Accès Anonyme et Possibilité d’Upload	3
3.2 Vulnérabilité Web – Absence d’En-têtes de Sécurité	5
3.3 Vulnérabilité SMTP – Open Relay et Commandes VRFY	6
3.4 Vulnérabilité WordPress – Version Obsolète (4.6.x).....	9
3.5 Vulnérabilité Système – Kernel Linux Obsolète (4.15.0-213-generic)	10
4. Préconisations et Recommandations.....	11
5. Tableau Récapitulatif des Vulnérabilités	12
6. Conclusion	13

1. Préambule et Contexte

Le client a mandaté notre équipe pour réaliser un audit de sécurité sur l'application **Bug&Blog Ltd**. Le test d'intrusion, réalisé en mode gray box, avait pour objectif de détecter et d'exploiter d'éventuelles vulnérabilités impactant la Confidentialité, l'Intégrité et la Disponibilité du système. Le périmètre inclut notamment les services FTP, SMTP, le site web (WordPress) ainsi que le système d'exploitation sous-jacent.

2. Exécutif – Résumé pour la Direction

Lors de notre test d'intrusion, nous avons identifié plusieurs vulnérabilités critiques au sein de l'infrastructure :

- **FTP en accès anonyme** : La possibilité de se connecter sans mot de passe, d'accéder à des fichiers sensibles (ex. "private.txt") et potentiellement d'upload un webshell. Cette faille, si exploitée, permettrait un contrôle complet du serveur (CVSS 10).
- **Configuration Web insuffisante** : Le site WordPress présente des failles de configuration au niveau des en-têtes de sécurité (absence de X-Frame-Options, X-XSS-Protection et X-Content-Type-Options) pouvant faciliter des attaques de type clickjacking et XSS.
- **Service SMTP mal configuré** : Le serveur SMTP (Postfix) montre des indices d'open relay et permet l'utilisation des commandes VRFY, exposant ainsi des informations sur les comptes utilisateurs.
- **WordPress obsolète** : La version 4.6.x de WordPress utilisée est vulnérable à plusieurs attaques connues, avec un risque élevé d'élévation de privilèges ou d'injection de code.
- **Système d'exploitation** : La version du kernel Linux (4.15.0-213-generic) est potentiellement vulnérable à des attaques d'élévation de privilèges, offrant un vecteur pour compromettre l'ensemble du système.

Ces vulnérabilités, évaluées tant sur le plan technique que sur leur impact métier, constituent un risque majeur pour l'organisation. Nous recommandons une mise à jour immédiate des services concernés et une reconfiguration des accès afin de limiter la surface d'attaque.

3. Analyse Technique – Détail des Vulnérabilités

3.1 Vulnérabilité FTP – Accès Anonyme et Possibilité d'Upload

- **Description :**

Le scan Nmap et les tests manuels ont confirmé que le service FTP sur le port 21 accepte les connexions en mode anonyme sans authentification. Il est possible d'accéder au répertoire, de télécharger le fichier "private.txt" et potentiellement d'upload un fichier (ex. webshell).

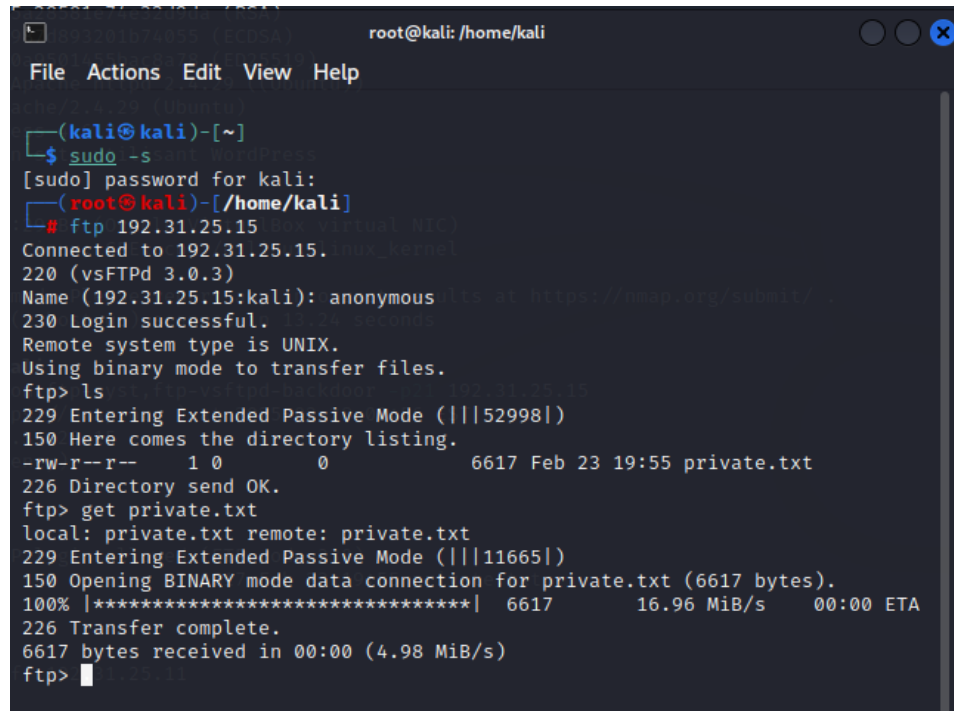
```
nmap --script ftp-anon,ftp-syst,ftp-vsftpd-backdoor -p21 192.31.25.15
```

```
(root@kali)-[/home/kali]
# nmap --script ftp-anon,ftp-syst,ftp-vsftpd-backdoor -p21 192.31.25.15
Starting Nmap 7.93 ( https://nmap.org ) at 2025-02-28 02:56 EST
Nmap scan report for 192.31.25.15
Host is up (0.00038s latency).

PORT      STATE SERVICE
21/tcp    open  ftp
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_-rw-r--r--  1 0      0      6617 Feb 23 19:55 private.txt
| ftp-syst:
|   STAT:
|   FTP server status:
|   Connected to ::ffff:192.31.25.11
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 2
|   vsFTPD 3.0.3 - secure, fast, stable
|_End of status
MAC Address: 08:00:27:F4:29:B0 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 7.18 seconds
```

ftp 192.31.25.15



```
root@kali: /home/kali
File Actions Edit View Help
(kali@kali)-[~]
$ sudo -s
[sudo] password for kali:
(root@kali)-[/home/kali]
# ftp 192.31.25.15
Connected to 192.31.25.15.
220 (vsFTPd 3.0.3)
Name (192.31.25.15:kali): anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||52998|)
150 Here comes the directory listing.
-rw-r--r-- 1 0 0 6617 Feb 23 19:55 private.txt
226 Directory send OK.
ftp> get private.txt
local: private.txt remote: private.txt
229 Entering Extended Passive Mode (|||11665|)
150 Opening BINARY mode data connection for private.txt (6617 bytes).
100% |*****| 6617 16.96 MiB/s 00:00 ETA
226 Transfer complete.
6617 bytes received in 00:00 (4.98 MiB/s)
ftp>
```

- **Impact :**
 - **Confidentialité :** Exposition de données sensibles.
 - **Intégrité & Disponibilité :** Risque de compromission totale du serveur via exécution de code à distance.
 - **CVSS :** 10.0 (critique)
 - **Remédiation :**
 - Désactiver l'accès anonyme sur le service FTP.
 - Restreindre les droits d'accès au répertoire, et isoler le répertoire FTP du répertoire web.
-

3.2 Vulnérabilité Web – Absence d'En-têtes de Sécurité

- **Description :**

Le serveur web ne fournit pas les en-têtes X-Frame-Options, X-XSS-Protection et X-Content-Type-Options, ce qui facilite des attaques telles que le clickjacking et certaines formes de Cross-Site Scripting.

```
nikto -h http://192.31.25.15
```

```
(root@kali)-[/home/kali]
# nikto -h http://192.31.25.15
- Nikto v2.1.6

+ Target IP: 192.31.25.15
+ Target Hostname: 192.31.25.15
+ Target Port: 80
+ Start Time: 2025-02-28 02:44:55 (GMT-5)

+ Server: Apache/2.4.29 (Ubuntu)
+ The anti-clickjacking X-Frame-Options header is not present.
+ The X-XSS-Protection header is not defined. This header can hint to the user agent to protect against some forms of XSS
+ Uncommon header 'link' found, with contents: <http://192.31.25.15/wp-json/>; rel="https://api.w.org/"
+ The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ Apache/2.4.29 appears to be outdated (current is at least Apache/2.4.37). Apache 2.2.34 is the EOL for the 2.x branch.
+ Web Server returns a valid response with junk HTTP methods, this may cause false positives.
+ OSVDB-3092: /private/: This might be interesting...
+ OSVDB-3233: /icons/README: Apache default file found.
+ /wp-links-opml.php: This WordPress script reveals the installed version.
+ OSVDB-3092: /license.txt: License file found may identify site software.
+ /wp-app.log: Wordpress' wp-app.log may leak application/system details.
+ /wordpresswp-app.log: Wordpress' wp-app.log may leak application/system details.
+ /: A Wordpress installation was found.
+ /wordpress: A Wordpress installation was found.
+ Cookie wordpress_test_cookie created without the httponly flag
+ /.well-known/carddav: CardDAV file may contain server info, per RFC-5785. See http://tools.ietf.org/html/rfc6764
+ 7915 requests: 0 error(s) and 16 item(s) reported on remote host
+ End Time: 2025-02-28 02:50:02 (GMT-5) (307 seconds)

+ 1 host(s) tested
```

- **Impact :**

- **Intégrité et Confidentialité :** Possibilité de manipulation de l'interface utilisateur et d'exécution de scripts malveillants.

- **CVSS : 6.5**

- **Remédiation :**

- Ajouter dans la configuration Apache (ou via .htaccess) les en-têtes suivants :
 - Header always set X-Frame-Options "SAMEORIGIN"
 - Header set X-XSS-Protection "1; mode=block"
 - Header set X-Content-Type-Options "nosniff"

3.3 Vulnérabilité SMTP – Open Relay et Commandes VRFY

- **Description :**

Le service SMTP (Postfix) sur le port 25 accepte les commandes de type VRFY et semble permettre l'envoi de mails vers des domaines externes sans authentification (open relay), ce qui peut être exploité pour l'envoi de spam ou l'énumération de comptes.

```
nmap -sV -p25 192.31.25.15
```

```
(root@kali)-[/home/kali]
# nmap -sV -p25 192.31.25.15
Starting Nmap 7.93 ( https://nmap.org ) at 2025-02-28 03:57 EST
Nmap scan report for 192.31.25.15
Host is up (0.00042s latency).

PORT      STATE SERVICE VERSION
25/tcp    open  smtp      Postfix smtpd
MAC Address: 08:00:27:F4:29:B0 (Oracle VirtualBox virtual NIC)
Service Info: Host: warbox-01

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.44 seconds
```

Vérification de la bannière postfix :

```
telnet 192.31.25.15 25
```

```
(root@kali)-[/home/kali]
# telnet 192.31.25.15 25
Trying 192.31.25.15 ...
Connected to 192.31.25.15.
Escape character is '^]'.
220 warbox-01 ESMTP Postfix (WARBOX __WARBOX-FLAG__)
```

Exécuter :

```
EHLO test.com
```

```
220 warbox-01 ESMTP Postfix (WARBOX __WARBOX-FLAG__)
EHLO test.com
250-warbox-01 Fri, 28 Feb 2025 09:10:53 GMT by in-cache-etu (squirrel/5.7)
250-PIPELINING
250-SIZE 10240000
250-VRFY
250-ETRN
250-STARTTLS
250-ENHANCEDSTATUSCODES
250-8BITMIME
250-DSN
250 SMTPUTF8
```

Test d'envoi de mail :

```
MAIL FROM:<test@test.com>
RCPT TO:<loic.guyot.etudes@gmail.com>
DATA
Ceci est un test
.
```

```
MAIL FROM:<test@test.com> 09:10:55 GMT by lecache-etu (squid/3.7)
RCPT TO:<votre_adresse_externe@exemple.com>
DATA
Ceci est un test
.
250 2.1.0 Ok
```

Test commande de type VRFY :

```
VRFY root
```

```
VRFY root
252 2.0.0 root
```

STARTTLS

```
openssl s_client -connect 192.31.25.15:25 -starttls smtp
```

```
(root@kali)-[/home/kali]
# openssl s_client -connect 192.31.25.15:25 -starttls smtp
CONNECTED(00000003)
Can't use SSL_get_servername
depth=0 CN = warbox-01
verify error:num=18:self-signed certificate
verify return:1
depth=0 CN = warbox-01
verify return:1
---
Certificate chain
 0 s:CN = warbox-01
  i:CN = warbox-01
  a:PKEY: rsaEncryption, 2048 (bit); sigalg: RSA-SHA256
  v:NotBefore: Feb 19 12:45:00 2025 GMT; NotAfter: Feb 17 12:45:00 2035 GMT
---
Server certificate
-----BEGIN CERTIFICATE-----
MIIC2TCCAcGgAwIBAgIUkKhIkvuC8mDm+GWP7CGWmkHueHkwDQYJKoZIhvcNAQEL
BQAwFDESMBAGA1UEAwJd2FyYm94LTAxMB4XDTE1MDIxOTEyNDUwMFoXDTE1MDIx
NzEyNDUwMFowFDESMBAGA1UEAwJd2FyYm94LTAxMIIIBjANBgkqhkiG9w0BAQEF
AAOCAQ8AMIIIBGKCAQEAw5RidECKS0L/oIPT4TZF7GKJq5vy4MP6LuMPqp0FDlJY
XZq1i3Kjde580TKQxP8itqSFRPqtBaJBdcuowerp5Njiu4ge1MOIBMzkns0jgKN0
geb7+KfmvxUQ30twwMQ0D5HSu6xooqpFo8DL0LDVdAwZwLGSFWpBL2XgTAY+ZpEw
YGSDAbs/TKzj0zavFZHoG+x1dDZfz8rBy1zQYr50Yg0E+2dpUMAKgFeoWdDMmeqo
9EB/SE5B09+mwdEmdPQ0hvXBx2qPwVU0hA3y3ay8cYzv760Izv2MleicquHNDJYy
ltWzG8WMWYXL6U18k7nvwso5ip5LKQVblpq/DWf4YwIDAQAABoyMwITAJBgNVHRME
AjaAMBQGA1UdEQQNMAuCCXdhcmJveC0wMTANBgkqhkiG9w0BAQsFAAOCAQEAuBDj
Ce+iTOAUIcdmUEeIzeDIF3xrT91pLeGbD0LDcJ1LNb6b147p0zvy08MSNdsi3UjL
44adgAl2mJYbDqRFBFBQbsq8fcy40TBK+/fVLS3xOG+aQMsmV6lHgn74MhmcMFi
1074Pn2Xh57Ma4m4olbHUz+qObnbJ/YMS+0LtlSNF5fFr11ug+TMckrk2FNkiiPO
EJOC3J1oWmMKn3RyKd74t4K9SfAqLXCGONMgbWp6/gyuju6+WHhGXgCYIZvVwhyn
DtjoZcvb5mCaYutD9kcvD01UZkuxQ4pScu6LYHshCL3bQ0c63CR2ij2WUvvprixAL
buRqzTioJwEt3wa9WQ=
-----END CERTIFICATE-----
subject=CN = warbox-01
issuer=CN = warbox-01
```

Accès aux certificats des différents utilisateurs (exemple ici avec l'utilisateur warbox-01)

- **Impact :**
 - **Intégrité et Confidentialité :** Possibilité d'usurper l'identité d'expéditeurs et de récupérer des informations sur les utilisateurs.
- **CVSS : 7.0**
- **Remédiation :**
 - Reconfigurer Postfix afin de désactiver l'open relay.
 - Désactiver les commandes VRFY et EXPN si elles ne sont pas nécessaires.
 - Mettre en place une authentification stricte et forcer l'utilisation de STARTTLS.

3.4 Vulnérabilité WordPress – Version Obsolète (4.6.x)

- **Description :**

Le site web utilise WordPress en version 4.6.x, une version obsolète connue pour contenir plusieurs failles (injections SQL, RCE via plugins, etc.).

```
nmap -sC -sV -p80 192.31.25.15
```

```
(root@kali)-[/home/kali]
# nmap -sC -sV -p80 192.31.25.15
Starting Nmap 7.93 ( https://nmap.org ) at 2025-02-28 04:48 EST
Nmap scan report for 192.31.25.15
Host is up (0.00040s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.4.29 ((Ubuntu))
|_http-title: Warbox | Un site utilisant WordPress
|_http-server-header: Apache/2.4.29 (Ubuntu)
|_http-generator: WordPress 4.6.29
MAC Address: 08:00:27:F4:29:B0 (Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.29 seconds
```

```
searchsploit wordpress 4.6.29
```

```
(root@kali)-[/home/kali]
# searchsploit wordpress 4.6.29
```

Exploit Title	Path
WordPress Core < 4.7.1 - Username Enumeration	php/webapps/41497.php
WordPress Core < 4.7.4 - Unauthorized Password Reset	linux/webapps/41963.txt
WordPress Core < 4.9.6 - (Authenticated) Arbitrary File Deletion	php/webapps/44949.txt
WordPress Core < 5.2.3 - Viewing Unauthenticated/Password/Private Posts	multiple/webapps/47690.md
WordPress Core < 5.3.x - 'xmlrpc.php' Denial of Service	php/dos/47800.py
WordPress Plugin Database Backup < 5.2 - Remote Code Execution (Metasploit)	php/remote/47157.rb
WordPress Plugin EZ SQL Reports < 4.11.37 - Multiple Vulnerabilities	php/webapps/39553.txt
WordPress Plugin iThemes Security < 7.0.3 - SQL Injection	php/webapps/38176.txt
WordPress Plugin Rest Google Maps < 7.11.18 - SQL Injection	php/webapps/44943.txt
WordPress Plugin User Role Editor < 4.25 - Privilege Escalation	php/webapps/48918.sh
WordPress Plugin UserPro < 4.9.17.1 - Authentication Bypass	php/webapps/45955.rb
WordPress Plugin UserPro < 4.9.21 - User Registration Privilege Escalation	php/webapps/43117.txt
	php/webapps/46883.txt

```
Shellcodes: No Results
```

⇒ Version obsolète de Wordpress

- **Impact :**

- **Intégrité et Confidentialité :** Risque d'exécution de code malveillant, d'injection SQL et de prise de contrôle du site.

- **CVSS : 8.0**

- **Remédiation :**

- Mettre à jour WordPress vers la dernière version stable.
- Examiner et mettre à jour (ou supprimer) les plugins et thèmes obsolètes.
- Appliquer les bonnes pratiques de sécurisation du CMS (sauvegardes régulières, renforcement des permissions, etc.).

3.5 Vulnérabilité Système – Kernel Linux Obsolète (4.15.0-213-generic)

- **Description :**

Le kernel Linux utilisé (version 4.15.0-213-generic) présente des vulnérabilités potentielles en termes d'élévation de privilèges, notamment exploitées via des PoC disponibles dans des bases d'exploits.

searchsploit linux kernel 4.15



Exploit Title	Path
Linux Kernel (Solaris 10 / < 5.10 138888-01) - Local Privilege Escalation	solaris/local/15962.c
Linux Kernel 2.4/2.6 (RedHat Linux 9 / Fedora Core 4 < 11 / Whitebox 4 / CentOS 4) - 'sock_sendpage()' Ring0 Privilege Escalation (5)	linux/local/9479.c
Linux Kernel 2.6.19 < 5.9 - 'Netfilter Local Privilege Escalation	linux/local/50135.c
Linux Kernel 4.10 < 5.1.17 - 'PIRACE_TRACEME' pkeyexec Local Privilege Escalation	linux/local/47163.c
Linux Kernel 4.15.x < 4.19.2 - 'map_write()' CAP_SYS_ADMIN' Local Privilege Escalation (cron Method)	linux/local/47164.sh
Linux Kernel 4.15.x < 4.19.2 - 'map_write()' CAP_SYS_ADMIN' Local Privilege Escalation (dbus Method)	linux/local/47165.sh
Linux Kernel 4.15.x < 4.19.2 - 'map_write()' CAP_SYS_ADMIN' Local Privilege Escalation (ldpreload Method)	linux/local/47166.sh
Linux Kernel 4.15.x < 4.19.2 - 'map_write()' CAP_SYS_ADMIN' Local Privilege Escalation (polkit Method)	linux/local/47167.sh
Linux Kernel 4.8.0 UDEV < 232 - Local Privilege Escalation	linux/local/41886.c
Linux Kernel < 4.15.4 - 'show_floppy' KASLR Address Leak	linux/local/44325.c
Linux Kernel < 4.16.11 - 'ext4_read_inline_data()' Memory Corruption	linux/dos/44832.txt
Linux Kernel < 4.17-rc1 - 'AF_LLC' Double Free	linux/dos/44579.c

Shellcodes: No Results

Faible par élévation de privilège exploitable

```
root@warbox-01:/home/warbox# cat /etc/ssh/sshd_config | grep PermitRootLogin
#PermitRootLogin prohibit-password
# the setting of "PermitRootLogin without-password".
root@warbox-01:/home/warbox#
```

root ne peut pas faire un simple "ssh root@ip" avec un mot de passe. Il faudra une clé SSH. C'est plus sûr que **PermitRootLogin yes**, mais moins restrictif que **PermitRootLogin no** (qui désactive totalement la connexion root).

- **Impact :**

- **Intégrité, Disponibilité et Confidentialité :** Possibilité d'atteindre un niveau d'accès élevé sur le système, compromettant l'ensemble du serveur.

- **CVSS : 8.5**

- **Remédiation :**

- Appliquer les derniers correctifs de sécurité en mettant à jour le kernel vers une version supportée et corrigée.
- Vérifier que toutes les mises à jour de sécurité de la distribution sont appliquées.

4. Préconisations et Recommandations

- **FTP :**
 - Désactiver l'accès anonyme.
 - Restreindre les permissions et isoler le répertoire FTP du répertoire web.

 - **Web (Serveur Apache) :**
 - Implémenter les en-têtes de sécurité (X-Frame-Options, X-XSS-Protection, X-Content-Type-Options).
 - Mettre à jour les logiciels et vérifier régulièrement les configurations de sécurité.

 - **SMTP (Postfix) :**
 - Reconfigurer le serveur pour désactiver l'open relay.
 - Restreindre et désactiver les commandes VRFY/EXPN inutiles.
 - Forcer l'utilisation de STARTTLS.

 - **WordPress :**
 - Mettre à jour le CMS vers une version récente.
 - Vérifier et mettre à jour l'ensemble des plugins et thèmes.
 - Renforcer les contrôles d'accès (identifiants forts, authentification à deux facteurs).

 - **Système :**
 - Mettre à jour le kernel Linux et appliquer les correctifs de sécurité fournis par la distribution.
 - Effectuer une révision périodique de la configuration système et des journaux de sécurité.
-

5. Tableau Récapitulatif des Vulnérabilités

ID	Vulnérabilité	CVSS	Impact(s)	Remédiation / Patch
V01	FTP en accès anonyme (upload / téléchargement sensible)	10.0	Confidentialité, Intégrité, Disponibilité (contrôle total possible)	Désactiver l'accès anonyme, restreindre les permissions, isoler le répertoire FTP du web.
V02	Absence d'en-têtes de sécurité (X-Frame, X-XSS, X-Content-Type)	6.5	Intégrité, Confidentialité	Ajouter les en-têtes dans la configuration Apache ou via .htaccess.
V03	SMTP – Open Relay et VRFY activé	7.0	Intégrité, Confidentialité	Reconfigurer Postfix pour désactiver l'open relay et restreindre VRFY/EXPN, forcer STARTTLS.
V04	WordPress obsolète (version 4.6.x)	8.0	Intégrité, Confidentialité, RCE potentiel	Mettre à jour WordPress et ses plugins/thèmes, renforcer la sécurité du CMS.
V05	Kernel Linux obsolète (4.15.0-213-generic)	8.5	Confidentialité, Intégrité, Disponibilité (élévation de privilèges)	Mettre à jour le kernel et appliquer tous les patches de sécurité disponibles.

6. Conclusion

L'audit a permis d'identifier plusieurs vulnérabilités critiques dans l'infrastructure de **Bug&Blog Ltd**. La vulnérabilité FTP en accès anonyme représente le vecteur le plus critique (CVSS 10), permettant potentiellement un contrôle total du système en cas d'exploitation réussie. À cela s'ajoutent des failles affectant le service SMTP, le CMS WordPress ainsi qu'un risque systémique lié à une version obsolète du kernel Linux. Nous recommandons vivement la mise en œuvre immédiate des mesures correctives détaillées dans ce rapport afin de renforcer la sécurité globale de l'application et de prévenir toute compromission future.

Ce rapport est confidentiel et destiné uniquement à l'usage interne du client. Les tests ont été réalisés dans le strict respect du périmètre défini et avec l'accord préalable de l'ensemble des parties concernées.
